Stimilon LLC
30 N Gould St #54165, Sheridan, WY 82801, USA

VERİ İŞLEME EK SÖZLEŞMESİ (DPA)

İşbu Veri İşleme Ek Sözleşmesi ("DPA"), Taraflar arasında akdedilen Hizmet Sözleşmesi'nin ("Ana Sözleşme") ayrılmaz bir ekidir ve Ana Sözleşme'nin 10.3 maddesi uyarınca düzenlenmiştir.

Veri Sorumlusu (Controller): INATURE LIMITED ("Müşteri")

Şirket kayıt numarası: 15360311 (Companies House)

Tescilli adresi: 182 New Road, Stoke Gifford, Bristol, England, BS34 8TG

Yetkili: Seyda Nur Ay Demir, Director. E-posta: info@inatureltd.com

Veri İşleyen (Processor): Stimilon LLC, Wyoming (ABD) kanunlarına göre kurulmuş limited şirket ("Hizmet Sağlayıcı")

Şirket kayıt numarası: 2026-001944457 (Wyoming Secretary of State, Filing ID)

Adres: 30 N Gould St #54165, Sheridan, WY 82801, ABD

Kayıtlı acente: Registered Agents Inc, 30 N Gould St Ste R, Sheridan, WY 82801, ABD

Yetkili: Bora Esen, Member. E-posta: bora.esn@outlook.com

Yürürlük tarihi: 05.09.2026 (Ana Sözleşme'nin imza tarihi).

1. Tanımlar

UK GDPR: 2018 tarihli Veri Koruma Kanunu (Data Protection Act 2018) ile birlikte uygulanan, Birleşik Krallık iç hukukuna aktarılmış Genel Veri Koruma Tüzüğü.

Kişisel Veri, İşleme, Veri Sahibi, Veri Sorumlusu, Veri İşleyen, Kişisel Veri İhlali: UK GDPR'daki anlamlarını taşır.

Alt İşleyici: Hizmet Sağlayıcı adına Kişisel Veri işleyen üçüncü taraf.

Kısıtlı Aktarım: UK GDPR Bölüm V anlamında Birleşik Krallık dışına yapılan aktarım.

IDTA: Bilgi Komiserliği (ICO) tarafından yayımlanan UK International Data Transfer Agreement.

TRA: Transfer Risk Assessment (Aktarım Risk Değerlendirmesi).

Bu DPA'da tanımlanmayan terimler Ana Sözleşme'deki anlamlarını taşır.

2. Roller ve kapsam

2.1 Bu DPA kapsamındaki işleme bakımından Müşteri **veri sorumlusu**, Hizmet Sağlayıcı **veri işleyendir**.

2.2 Hizmet Sağlayıcı, Kişisel Veriyi yalnızca Ana Sözleşme'de tanımlanan hizmetleri yerine getirmek amacıyla ve Müşteri'nin yazılı talimatları doğrultusunda işler.

2.3 **Kapsam sınırı.** Bu DPA yalnızca Hizmet Sağlayıcı'nın fiilen işlediği Kişisel Veriyi kapsar. Müşteri'nin Shopify, Google, eBay ve benzeri platformlarla olan doğrudan ilişkileri bu DPA'nın kapsamında değildir; bu platformlar bakımından Müşteri kendi veri sorumlusu sıfatıyla hareket eder ve kendi sözleşmelerine sahiptir. Bu DPA o sözleşmelerin yerine geçmez.

2.4 Hizmet Sağlayıcı, Kişisel Veriyi kendi amaçları için kullanmaz. Özellikle: satmaz, kiralamaz, kendi pazarlama veya reklam faaliyetinde kullanmaz, üçüncü taraflarla ticari amaçla paylaşmaz ve **herhangi bir yapay zekâ modelinin eğitimine sunmaz.**

3. İşleme talimatları

3.1 Hizmet Sağlayıcı, Kişisel Veriyi yalnızca Ek A'da tanımlanan amaçlar için ve Müşteri'nin belgelenmiş talimatları doğrultusunda işler. Ana Sözleşme ve bu DPA, Müşteri'nin başlangıçtaki tam talimatını oluşturur.

3.2 Hizmet Sağlayıcı, kendisine verilen bir talimatın UK GDPR'ı veya diğer geçerli veri koruma mevzuatını ihlal ettiği kanaatine varırsa, işlemeyi durdurur ve Müşteri'yi gecikmeksizin bilgilendirir.

3.3 Hizmet Sağlayıcı'nın tabi olduğu hukuk bir işlemeyi zorunlu kılıyorsa, hukuken yasak olmadıkça Hizmet Sağlayıcı işleme öncesinde Müşteri'yi bilgilendirir.

4. Gizlilik

4.1 Hizmet Sağlayıcı, Kişisel Veriye erişimi olan kişilerin gizlilik yükümlülüğü altında olmasını sağlar.

4.2 Erişim, hizmetin yerine getirilmesi için gerçekten ihtiyacı olan kişilerle sınırlıdır.

5. Güvenlik

5.1 Hizmet Sağlayıcı, UK GDPR madde 32 uyarınca, riske uygun düzeyde teknik ve idari tedbirleri uygular. Uygulanan tedbirlerin listesi **Ek B**'dedir.

5.2 Tedbirler belirlenirken işlemenin niteliği, kapsamı, bağlamı, amaçları ve veri sahiplerinin hak ve özgürlükleri bakımından oluşan risk dikkate alınmıştır.

5.3 Hizmet Sağlayıcı, Ek B'deki tedbirleri güvenlik seviyesini düşürmeyecek şekilde güncelleyebilir.

6. Alt işleyiciler

6.1 Müşteri, Hizmet Sağlayıcı'nın **Ek C**'de listelenen Alt İşleyicileri kullanmasına genel olarak izin verir.

6.2 Hizmet Sağlayıcı, bir Alt İşleyici eklemeden veya değiştirmeden **en az 30 gün önce** Müşteri'yi yazılı olarak bilgilendirir.

6.3 Müşteri, bildirim tarihinden itibaren 30 gün içinde makul ve veri korumasına dayalı gerekçelerle yazılı olarak itiraz edebilir. Taraflar iyi niyetle bir çözüm arar. Çözüm bulunamazsa Müşteri, etkilenen hizmetleri cezasız olarak feshedebilir.

6.4 Hizmet Sağlayıcı, her Alt İşleyici ile bu DPA'dakine esasen eşdeğer yükümlülükleri içeren yazılı bir sözleşme akdeder ve Alt İşleyici'nin fiillerinden Müşteri'ye karşı **kendi fiiliymiş gibi sorumludur.**

7. Veri sahibi hakları

7.1 Hizmet Sağlayıcı, bir veri sahibinden erişim, düzeltme, silme, kısıtlama, taşınabilirlik veya itiraz talebi alırsa, talebi kendisi yanıtlamaz ve **gecikmeksizin, en geç 3 iş günü içinde** Müşteri'ye iletir.

7.2 Hizmet Sağlayıcı, işlemenin niteliğini dikkate alarak, Müşteri'nin veri sahibi taleplerini yanıtlama yükümlülüğünü yerine getirmesine uygun teknik ve idari tedbirlerle makul ölçüde yardımcı olur.

7.3 **Pratik not.** Kişisel Veri Hizmet Sağlayıcı'da kalıcı olarak saklanmadığı (bkz. Ek A, "Saklama") ve kaynağı Müşteri'nin Shopify hesabı olduğu için, veri sahibi taleplerinin fiilen yerine getirilmesi Müşteri'nin Shopify hesabı üzerinden yapılır. Shopify'daki bir kayıt silindiğinde Hizmet Sağlayıcı'nın görüntüsünden de düşer.

8. Kişisel veri ihlali

8.1 Hizmet Sağlayıcı, bir Kişisel Veri İhlalinden haberdar olduktan sonra **24 saat içinde** Müşteri'ye yazılı bildirimde bulunur.

8.2 Bildirim, o an bilinebildiği ölçüde şunları içerir: ihlalin niteliği, etkilenen veri kategorileri ve yaklaşık veri sahibi sayısı, muhtemel sonuçlar, alınan veya alınması önerilen tedbirler ve irtibat noktası.

8.3 Hizmet Sağlayıcı, ihlalin araştırılması, azaltılması ve giderilmesinde ve Müşteri'nin ICO'ya bildirim ile veri sahiplerine bilgilendirme yükümlülüklerinde makul ölçüde yardımcı olur.

8.4 Hizmet Sağlayıcı, Müşteri'nin yazılı onayı olmadan bir ihlali veri sahiplerine veya kamuya duyurmaz; hukuken zorunlu olduğu hâller saklıdır.

Stimilon LLC
30 N Gould St #54165, Sheridan, WY 82801, USA

9. Veri koruma etki değerlendirmesi

9.1 Hizmet Sağlayıcı, işlemenin niteliğini ve kendisinde bulunan bilgiyi dikkate alarak, Müşteri'nin UK GDPR madde 35 ve 36 kapsamındaki veri koruma etki değerlendirmesi ve önceden danışma yükümlülüklerine makul ölçüde yardımcı olur.

10. Silme ve iade

10.1 Ana Sözleşme sona erdiğinde Hizmet Sağlayıcı, Müşteri'nin yazılı tercihine göre Kişisel Veriyi iade eder veya güvenli şekilde siler ve mevcut kopyaları imha eder. Hukuken saklanması zorunlu olan veriler saklı kalır.

10.2 Hizmet Sağlayıcı, Müşteri'nin hesaplarına ait erişim bilgilerini kullanmayı bırakır ve kendi kontrolündeki kimlik bilgilerini imha eder.

10.3 Talep hâlinde Hizmet Sağlayıcı, silme işleminin tamamlandığına dair yazılı teyit verir.

10.4 **Pratik not.** Hizmet Sağlayıcı Kişisel Veriyi kalıcı olarak saklamadığı için, bu madde uygulamada erişim bilgilerinin imhası ve Müşteri'nin hesaplarından çıkış anlamına gelir.

11. Denetim ve bilgi

11.1 Hizmet Sağlayıcı, bu DPA'daki yükümlülüklere uyduğunu göstermek için gerekli bilgiyi Müşteri'ye sunar.

11.2 Müşteri, yılda bir kez, en az 30 gün önceden yazılı bildirimde bulunmak kaydıyla denetim talep edebilir. Denetim normal çalışma saatlerinde yapılır, faaliyeti makul olmayan ölçüde aksatmaz ve gizlilik yükümlülüğüne tabidir.

11.3 Bir Kişisel Veri İhlali sonrasında veya ICO'nun talebi hâlinde bu sıklık sınırı uygulanmaz.

11.4 Denetimin makul masrafları Müşteri'ye aittir; denetimde esaslı bir uyumsuzluk tespit edilirse masraflar Hizmet Sağlayıcı'ya aittir.

12. Uluslararası aktarım

12.1 Hizmet Sağlayıcı Amerika Birleşik Devletleri'nde kuruludur ve hizmeti yerine getirirken Birleşik Krallık'taki veri sahiplerine ait Kişisel Veriye erişir. Bu, UK GDPR Bölüm V anlamında **Kısıtlı Aktarım**dır.

12.2 Bu aktarım için Taraflar, bu DPA ile birlikte **IDTA**'yı imzalar. IDTA, bu DPA'nın ayrılmaz ekidir.

12.3 Aktarımın risk değerlendirmesi **TRA**'da yapılmıştır. TRA'yı Müşteri veri sorumlusu sıfatıyla imzalar; Hizmet Sağlayıcı gerekli teknik bilgiyi sağlar ve bu bilginin doğruluğunu teyit eder.

12.4 Bu belgeler yürürlüğe girmeden Hizmet Sağlayıcı hiçbir Kısıtlı Aktarım gerçekleştirmez.

12.5 Hizmet Sağlayıcı, kendisine bir kamu otoritesinden Kişisel Veriye erişim talebi ulaşırsa, hukuken yasak olmadıkça Müşteri'yi gecikmeksizin bilgilendirir, talebin hukuka uygunluğunu inceler ve hukuken mümkün olan itiraz yollarını kullanır.

13. Süre ve genel hükümler

13.1 Bu DPA, Ana Sözleşme yürürlükte olduğu ve Hizmet Sağlayıcı Kişisel Veri işlediği sürece yürürlüktedir.

13.2 Bu DPA ile Ana Sözleşme arasında Kişisel Veri işlemeye ilişkin bir çelişki olması hâlinde bu DPA öncelikli uygulanır. Bu DPA ile IDTA arasında bir çelişki olması hâlinde IDTA öncelikli uygulanır.

13.3 Ana Sözleşme'nin uygulanacak hukuk, yetki, sorumluluk ve bildirimlere ilişkin hükümleri bu DPA için de geçerlidir.

EK A: İŞLEME DETAYLARI

A.1 İşlemenin konusu

Müşteri'nin Shopify tabanlı e-ticaret altyapısının bakımı, işletilmesi ve yönetimi; buna Müşteri için geliştirilmiş bir yönetim panelinin işletilmesi dahildir.

A.2 İşlemenin süresi

Ana Sözleşme süresince ve Ana Sözleşme'nin 11.3 maddesindeki 30 günlük geçiş dönemi boyunca.

A.3 İşlemenin niteliği ve amacı

Amaç	*Açıklama*
Satış paneli görüntüleme	Müşteri'nin siparişlerini, kanal kırılımını ve en çok satan ürünlerini Müşteri'ye göstermek
Terk edilmiş sepet görüntüleme	Müşteri'nin kurtarılabilir sepetlerini ve bunların iletişim kurulabilir olup olmadığını Müşteri'ye göstermek
Analitik raporlama	Trafik ve arama görünürlüğü verisini Müşteri'ye göstermek
Ürün ve içerik yönetimi	Müşteri adına ürün ve blog içeriği oluşturma ve düzenleme
Teknik bakım ve hata giderme	Sistemlerin çalışır tutulması

İşleme faaliyetleri: **toplama (okuma), görüntüleme, düzenleme ve yapılandırma.** Profilleme, otomatik karar alma, zenginleştirme ve üçüncü taraflara aktarma **yapılmaz.**

Stimilon LLC
30 N Gould St #54165, Sheridan, WY 82801, USA

A.4 Kişisel Veri kategorileri

Hizmet Sağlayıcı'nın fiilen eriştiği kişisel veri **dar kapsamlıdır** ve şunlardan ibarettir:

Kategori	*Kaynak*	*Not*
E-posta adresi	Terk edilmiş sepet kayıtları (Shopify `checkouts`)	Tek doğrudan tanımlayıcıdır
Sepet tutarı, ürün adları, tarih	Terk edilmiş sepet kayıtları	Tek başına kişiyi tanımlamaz

Sipariş kayıtları kişisel veri içermez. Hizmet Sağlayıcı'nın sipariş verisinden okuduğu alanlar yalnızca şunlardır: oluşturma tarihi, toplam tutar, satış kanalı, giriş sayfası, yönlendiren site ve satır kalemleri. **Ad, soyad, adres, telefon numarası, ödeme bilgisi ve sipariş e-postası okunmaz ve işlenmez.**

Analitik verisi (Google Analytics 4 ve Search Console) yalnızca **toplulaştırılmış** biçimde görüntülenir; bireysel kullanıcı kaydı işlenmez.

Blog otomasyonu **hiçbir kişisel veri işlemez**; yalnızca yayın içeriği üretir.

A.5 Özel nitelikli veri

Yoktur. UK GDPR madde 9 ve 10 kapsamındaki özel nitelikli kişisel veri ile ceza mahkûmiyetlerine ilişkin veri işlenmez.

A.6 Veri sahibi kategorileri

Müşteri'nin web mağazasında alışverişi tamamlamadan bırakan Birleşik Krallık'taki tüketiciler.

A.7 Yaklaşık hacim

Yönetim paneli, herhangi bir anda **en fazla 15 terk edilmiş sepet kaydı** çeker ve görüntüler; görünüm en yeni 15 kayıtla sınırlanmıştır. Sözleşme süresi boyunca işlenen benzersiz veri sahibi sayısı bundan yüksek olabilir ve Hizmet Sağlayıcı tarafından kaydedilmez.

A.8 Saklama

Hizmet Sağlayıcı **Kişisel Veriyi saklamaz.**

Yönetim paneli veritabanı içermez. Veri, Müşteri paneli her açtığında Shopify Admin API'sinden okunur, sunucu belleğinde işlenir, tarayıcıya gönderilir ve istek tamamlandığında bellekten düşer. Diske yazma, önbelleğe alma, dışa aktarma ve yedekleme yapılmaz.

Bu doğrulanmıştır: yönetim paneli uygulamasının bağımlılıkları yalnızca Next.js, React ve bir zengin metin editöründen (TipTap) ibarettir; herhangi bir veritabanı, ORM, nesne deposu veya kalıcı önbellek bileşeni bulunmamaktadır.

Kişisel Verinin kalıcı kaydı yalnızca **Müşteri'nin kendi Shopify hesabında** bulunur.

EK B: TEKNİK VE İDARİ TEDBİRLER

B.1 Erişim kontrolü

- Yönetim paneline erişim paylaşımlı parola ile korunmaktadır. Parola ortam değişkeni olarak tutulur, kaynak kodda bulunmaz.
- Parola doğrulaması **sabit zamanlı karşılaştırma** ile yapılır (SHA-256 özet üzerinden), böylece zamanlama saldırısına kapalıdır.
- Oturum çerezi **HMAC-SHA256** ile imzalanır; imzasız veya geçersiz imzalı çerez kabul edilmez.
- Oturum çerezi `httpOnly` ve `sameSite=lax` olarak ayarlanır, üretim ortamında `secure` bayrağı ile yalnızca HTTPS üzerinden gönderilir.
- Oturum ömrü **7 gün** ile sınırlıdır.
- Parola veya imzalama anahtarı tanımlı değilse sistem **kapalı hâlde başarısız olur** (fail closed); kimlik doğrulaması atlanamaz.
- Erişim, hizmeti yerine getirmek için ihtiyacı olan kişilerle sınırlıdır.

B.2 Aktarımda ve beklemede şifreleme

- Tüm veri aktarımı **HTTPS/TLS** üzerinden yapılır: tarayıcı ile panel arasında, panel ile Shopify Admin API arasında ve panel ile Google API'leri arasında.
- **Beklemede şifreleme uygulanabilir değildir**, çünkü Hizmet Sağlayıcı Kişisel Veriyi diskte saklamaz (bkz. Ek A.8).

B.3 Sır yönetimi

- API anahtarları, erişim jetonları ve parolalar barındırma sağlayıcısının şifreli ortam değişkeni deposunda tutulur.
- Sırlar kaynak koda yazılmaz; ortam dosyaları sürüm kontrolünden hariç tutulmuştur.
- Shopify erişim jetonu `client_credentials` akışıyla otomatik yenilenir; uzun ömürlü statik jeton kullanılmaz.

B.4 Veri minimizasyonu

- Yönetim paneli, Shopify sipariş kaydından **yalnızca kişisel veri içermeyen alanları** okur (bkz. Ek A.4). Ad, adres, telefon ve ödeme alanları hiçbir noktada talep edilmez.

- Terk edilmiş sepet görünümü en yeni 15 kayıtla sınırlıdır.
- Shopify uygulama izinleri gereken en dar kapsamla sınırlıdır.

B.5 Kalıcılığın olmaması

- Yönetim panelinde veritabanı, nesne deposu veya kalıcı önbellek yoktur.
- Kişisel Veri işleme **geçicidir** ve istek süresiyle sınırlıdır.
- Bu, saklama, yedekleme ve toplu sızıntı risklerini yapısal olarak ortadan kaldırır.

B.6 Dayanıklılık ve süreklilik

- Sistemler yönetilen bir barındırma platformunda çalışır; platform altyapı düzeyinde yedeklilik ve izleme sağlar.
- Kişisel Verinin doğruluk kaydı Müşteri'nin Shopify hesabındadır; Hizmet Sağlayıcı tarafındaki bir kesinti veri kaybına yol açmaz.

B.7 Kod ve değişiklik yönetimi

- Tüm değişiklikler sürüm kontrolü altındadır ve izlenebilir.
- Dağıtımlar sürümlenmiştir ve geri alınabilir.
- Bağımlılıklar düzenli olarak güncellenir.

B.8 Test verisi

- Geliştirme ve test sırasında gerçek müşteri verisi kullanılmaz; sistem gerçek veri yokken sahte örnek kayıtlarla çalışacak şekilde tasarlanmıştır.

EK C: ALT İŞLEYİCİ LİSTESİ

İmza tarihi itibarıyla onaylanmış Alt İşleyiciler:

Alt İşleyici	*Rolü*	*Konum*	*Kişisel veri işliyor mu*
Railway Corporation	Yönetim paneli ve blog otomasyonu servislerinin barındırılması	ABD, `us-west2` bölgesi (Oregon)	**Evet.** Kişisel Veri barındırılan sunucunun belleğinden geçer. Diske yazılmaz.
OpenRouter, Inc.	Blog içeriği üretimi için model yönlendirme	ABD	**Hayır.** Yalnızca yayın içeriği işlenir; müşteri kaynaklı kişisel veri gönderilmez.

Alt işleyici olmayan taraflar

Aşağıdaki taraflar Hizmet Sağlayıcı'nın Alt İşleyicisi **değildir**. Müşteri bunlarla doğrudan veri sorumlusu sıfatıyla kendi ilişkisine sahiptir ve kendi sözleşmelerini akdetmiştir:

- **Shopify** (Müşteri'nin e-ticaret platformu ve kişisel verinin kayıt sistemi)
- **Google** (Google Analytics 4 ve Search Console)
- **eBay** (Müşteri'nin pazaryeri kanalı, Ana Sözleşme kapsamı dışındadır)

Hizmet Sağlayıcı bu platformlara Müşteri'nin kendisine verdiği yetkiyle erişir.

İmzalar

Veri Sorumlusu: INATURE LIMITED

İmza: _____

Ad: Seyda Nur Ay Demir

Unvan: Director

Tarih: 05.09.2026

Veri İşleyen: Stimilon LLC

İmza: _____

Ad: Bora Esen

Unvan: Member

Tarih: 05.09.2026